

1. Executive Summary

Subject: HIPAA Security Rule Assessment – Oak Street Family Practice **Date:** January 13, 2026

Oak Street Family Practice operates a hybrid IT environment with on-premise intake stations and cloud-based Electronic Health Records (EHR). This assessment focuses on the integrity and availability of Protected Health Information (PHI) against the rising threat of ransomware in the healthcare sector. The review highlights gaps in disaster recovery and endpoint protection.

2. Scope & Asset Inventory

- **Physical Scope:** Main Reception, Examination Rooms 1-4, Server Closet.
- **Assets:**
 - **Data:** PHI (Diagnoses, SSNs, Insurance Info), Billing Records.
 - **Systems:** "CureMD" (EHR Software), Local File Server (Scans/Images).
 - **People:** Receptionists, Nurses, Physicians.

3. Threat Actors & Motivations

- **Cybercriminal Groups:** Motivated by financial gain (Ransomware/Extortion).
- **Malicious Insider:** Disgruntled employee seeking to leak patient history.
- **Loss/Theft:** Opportunistic theft of hardware containing local data.

4. Compliance Obligations

- **HIPAA Security Rule:**
 - **Technical Safeguards:** Access Control, Audit Controls, Integrity, Transmission Security.
 - **Physical Safeguards:** Workstation Use/Security.

5. Risk Assessment Matrix

Risk ID	Risk Description	Threat Source	Vulnerability	L	I	Score	Level
H-01	Ransomware Infection	Crime Syndicate	Phishing / Unpatched OS	4	5	20	Critical
H-02	Reception Area Snooping	Patient/Visitor	Monitors facing public area	5	2	10	Med
H-03	Theft of Unencrypted Laptop	Thief	Lack of BitLocker/FDE	2	5	10	Med

6. Recommended Controls

- **Technical (H-01):** Deploy EDR (Endpoint Detection & Response); implement immutable offsite backups (3-2-1 strategy) to ensure availability during ransomware events.
- **Physical (H-02):** Install privacy filters on all reception monitors; reorient desks away from the waiting room.
- **Technical (H-03):** Enforce Full Disk Encryption (BitLocker) on all mobile devices via MDM.

7. Business Impact Narrative

"A ransomware attack rendering the EHR inaccessible would halt patient care immediately, forcing the clinic to divert emergencies and cancel appointments. Beyond the HIPAA fines (up to \$50k per violation), the inability to access patient allergies or medication history poses a life-safety risk, which creates liability far exceeding IT restoration costs."